Ticket di allerta A-2703

ID ticket	Messaggio di allerta	Gravità	Dettagli	Stato del ticket
A-2703	SERVER-MAIL Phishing attempt possible download of malware	Media	L'utente potrebbe aver aperto un'email dannosa e averne aperto gli allegati o cliccato sui link.	Escalation

Commenti al ticket	Passo il ticket a un analista SOC di secondo livello. L'allerta è scattata per una possibile email di phishing arrivata alla casella delle risorse umane. Dopo aver letto il messaggio e controllato l'allegato penso che sia un attacco vero e non un falso positivo. Ecco cosa non torna. Il nome visualizzato del mittente è "Def Communications", ma il messaggio è firmato "Clyde West". L'indirizzo del mittente è una lunga sequenza di caratteri casuali su un dominio .su, che non è quello che userebbe chi si candida a un lavoro. L'oggetto e il testo hanno errori di ortografia e di grammatica ("Egnieer", "Ingergy", "writing for to express"), e il nome dell'azienda nel saluto non è scritto come il dominio a cui è stato mandato il messaggio. L'email dice che sono allegati un curriculum e una lettera di presentazione, ma l'unico allegato è bfsvc.exe, un file eseguibile. Nel testo c'è anche la password per aprirlo, un trucco noto per impedire agli antivirus della posta di guardare dentro il file. L'hash del file indicato nel ticket corrisponde a un file dannoso già noto nella ricerca sulla threat intelligence. Il ticket dice che l'utente potrebbe aver aperto l'allegato, e finché non si dimostra il contrario considero quel computer compromesso. La gravità dell'allerta è media, ma un file dannoso che forse è stato eseguito è più serio di così, quindi propongo di portarla ad alta. Il secondo livello dovrebbe isolare il computer, controllare cosa ha fatto il file dopo l'esecuzione e cercare altre copie della stessa email nelle altre caselle.

Informazioni aggiuntive

Mittente	Def Communications, 76tguyhh6tgftrt7tg.su (114.114.114.114)
Destinatario	hr@inergy.com (176.157.125.93)
Inviata	Mercoledì 20 luglio 2022, 09:30:14
Oggetto	Re: Infrastructure Egnieer role
Allegato	bfsvc.exe
Hash del file (SHA-256)	54e6ea47eb04634d3e87fd7787e2136ccfbcc80ade34f246a12cf93bab527f6b
Nota	Il testo dell'email contiene la password dell'allegato. L'ho lasciata fuori da questo documento di proposito.

Come ho seguito il playbook sul phishing

Passo del playbook	Cosa ho fatto	Esito
2. Valutare l'allerta	Ho letto la gravità, i dati di mittente e destinatario, l'oggetto e il testo. Non ho aperto nulla sul mio dispositivo.	Diversi segnali sospetti, elencati nei commenti al ticket
3.0 Link o allegati?	Ho guardato cosa accompagnava l'email.	Un allegato eseguibile, nessun link
3.1 Sono dannosi?	Ho controllato l'hash del file con uno strumento di threat intelligence.	File dannoso già noto
3.2 Aggiornare ed escalare	Ho scritto un riepilogo dei risultati, messo lo stato su Escalation e passato il ticket al secondo livello.	Fatto
4. Chiudere il ticket	Non si applica, perché l'allegato è dannoso.	Il ticket resta aperto